

Cirque Corporation

Nonconformity and Corrective Action Policy

Document ID: IS-CIRQ-P-023-G

Category: ISMS Support Process

Division: Policy

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: Executive Committee

Generated: March 02, 2026

1. Purpose

The purpose of this policy is to establish Cirque's commitment and framework for identifying, addressing, and preventing nonconformities within its Information Security Management System (ISMS). This policy ensures that identified deviations from requirements are promptly corrected, their root causes are eliminated, and measures are taken to prevent recurrence, thereby driving continual improvement of the ISMS. This policy aligns with ISO/IEC 27001:2022 Clause 10.1 (Continual improvement - Nonconformity and corrective action).

****2. Scope****

2. Scope

This policy applies to all nonconformities related to Cirque's ISMS, whether identified through internal audits, management reviews, incident management, performance monitoring, external audits, or other means. It covers all processes, controls, and personnel within the defined ISMS scope across all global operations (US, Taipei, China).

****3. Definitions****

3. Definitions

- **Nonconformity (NC):** A non-fulfillment of a requirement. In the context of the ISMS, this could be a deviation from ISO 27001 requirements, Cirque's own ISMS requirements (e.g., policies, procedures), or legal, regulatory, or contractual obligations.
- **Corrective Action (CA):** Action to eliminate the cause of a detected nonconformity and to prevent recurrence.
- **Root Cause Analysis (RCA):** A systematic process for identifying the underlying causes of a nonconformity, rather than just addressing its symptoms.
- **Corrective Action Request (CAR):** A formal document or record used to initiate and track the process of addressing a nonconformity and implementing corrective actions.

****4. Policy Requirements****

4. Policy Requirements

4.1. Identification and Reporting of Nonconformities: a. Any personnel who identify a nonconformity, or potential nonconformity, related to the ISMS shall report it to their manager or the ISMS Owner/Security Team. b. Nonconformities can be identified through various sources, including: * Internal and external audits. * Security incident investigations. * Monitoring and measurement activities. * Management reviews. * Feedback from interested parties (e.g., customers, regulators). * Employee suggestions or observations.

4.2. Response to Nonconformities: a. When a nonconformity occurs, Cirque shall: 1. **React to the nonconformity:** Take immediate action

to control and correct it (i.e., address the symptoms). 2. ****Deal with the consequences:**** Address any immediate impacts or damages. 3. ****Evaluate the need for action to eliminate the cause(s):**** Determine if a corrective action is necessary to prevent recurrence.

****4.3. Root Cause Analysis (RCA):**** a. For all significant nonconformities (e.g., those impacting critical systems, recurring issues, or high-risk areas), a Root Cause Analysis shall be performed. b. The RCA process aims to identify the \"why\" behind the nonconformity, not just the \"what.\" Techniques may include 5 Whys, Fishbone Diagram, etc.

****4.4. Corrective Action Planning and Implementation:**** a. Based on the RCA, a corrective action plan shall be developed. This plan must include: * Specific actions to address the root cause(s). * Clear responsibilities for implementation. * Realistic target dates for completion. * Resources required. b. Corrective actions shall be proportionate to the significance of the nonconformity and the risks involved. c. Actions shall be implemented in a timely manner.

****4.5. Verification of Effectiveness:**** a. Once corrective actions have been implemented, their effectiveness shall be verified. This involves confirming that the action taken has eliminated the root cause and prevented recurrence. b. Verification methods may include re-auditing, re-testing, reviewing new performance data, or observing updated processes.

****4.6. Review of Corrective Actions:**** a. The results of corrective actions shall be reviewed periodically (e.g., during management reviews) to ensure their ongoing effectiveness and to identify any systemic issues or further opportunities for improvement.

****4.7. Documentation and Record Keeping:**** a. All nonconformities and

subsequent corrective actions shall be documented using the IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form. b. Records shall be maintained as documented information of: * The nature of the nonconformities and any subsequent actions taken. * The results of any corrective action taken. c. These records are crucial for demonstrating compliance and for input into continual improvement.

****5. Responsibilities****

5. Responsibilities

- ****Executive Committee:**** Provides leadership and resources for managing nonconformities and corrective actions; reviews significant nonconformities during management reviews.
- ****ISMS Owner (e.g., Information Security Officer/IT Manager):**** Overall responsibility for the nonconformity and corrective action process; ensures proper logging, tracking, and closure of CARs; reports on the status of nonconformities to top management.
- ****Process Owners/Action Item Owners:**** Responsible for investigating nonconformities within their area, conducting RCA, developing and implementing corrective action plans, and confirming effectiveness.
- ****Internal Auditors:**** Responsible for identifying nonconformities during audits and verifying the effectiveness of corrective actions.
- ****All Personnel:**** Responsible for reporting nonconformities and supporting the implementation of corrective actions within their scope.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-001-G: Information Security Policy

- IS-CIRQ-P-021-G: Monitoring, Measurement, Analysis, and Evaluation Policy

- IS-CIRQ-PR-023-G: Internal Audit Procedure

- IS-CIRQ-F-006-G: Internal Audit Report Template

- IS-CIRQ-P-022-G: Management Review Policy

- IS-CIRQ-PR-025-G: Corrective Action Procedure

- IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form

- IS-CIRQ-P-024-G: Continual Improvement Policy

****7. Policy Review****

7. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, processes for handling nonconformities, or relevant standards.